

TAVARES CLAIMS SERVICES, INC. — ENTERPRISE RISK REGISTER

Prepared by Chris Morrissey | Review cycle: Quarterly | Fictional organization. Created for portfolio demonstration purposes.

| Risk ID | Date Identified | Risk Category                        | Risk Description                                                                                                      | Asset / Process Affected                  | Threat Source                           | Vulnerability                                                                                 | Inherent Likelihood (1-5) | Inherent Impact (1-5) | Inherent Risk Score | Inherent Risk Level | Existing Controls                                                                                           | Control Effectiveness (1-5) | Residual Likelihood (1-5) | Residual Impact (1-5) | Residual Risk Score | Residual Risk Level | Risk Treatment | Treatment Plan / Next Actions                                                                                                                                                                                                                         | Risk Owner                    | Target Remediation Date | Status      |
|---------|-----------------|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------|-------------------------------------------|-----------------------------------------|-----------------------------------------------------------------------------------------------|---------------------------|-----------------------|---------------------|---------------------|-------------------------------------------------------------------------------------------------------------|-----------------------------|---------------------------|-----------------------|---------------------|---------------------|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------|-------------------------|-------------|
| R-001   | 2026-01-08      | Data Protection                      | Unencrypted PHI backups stored in legacy on-prem NAS accessible to broader IT staff than required                     | Patient claims data warehouse             | External attacker / Malicious insider   | Backup volumes not encrypted at rest; excessive access group membership                       | 4                         | 5                     | 20                  | Critical            | Encrypted nightly backups migrated to AWS S3 with SSE-KMS; access restricted to 3-person backup admin group | 4                           | 2                         | 2                     | 4                   | Low                 | Mitigate       | Complete migration to encrypted cloud backup by Q2; decommission legacy NAS; run access recertification                                                                                                                                               | VP Infrastructure             | 2026-05-15              | In Progress |
| R-002   | 2026-01-08      | Access Control                       | Shared service account used by three ETL pipelines with standing admin privileges to production database              | Production PHI database                   | Insider threat / Credential compromise  | No individual accountability; standing privileged access; password not rotated                | 4                         | 5                     | 20                  | Critical            | Service account rotated quarterly; database activity logging enabled                                        | 3                           | 3                         | 2                     | 6                   | Medium              | Mitigate       | Migrate ETL to IAM role-based auth (no static creds); implement just-in-time privileged access via PAM tool                                                                                                                                           | Director of Engineering       | 2026-04-30              | In Progress |
| R-003   | 2026-01-15      | Third-Party / Vendor                 | Claims clearinghouse vendor (ClaimLink Corp) has not provided a current SOC 2 Type II report                          | Eligibility verification workflow         | Vendor breach / Supply chain compromise | No independent assurance of vendor control environment in past 18 months                      | 3                         | 4                     | 12                  | High                | Vendor contract includes data protection addendum; annual security questionnaire on file                    | 2                           | 3                         | 3                     | 9                   | Medium              | Mitigate       | Escalate to procurement; request updated SOC 2 Type II or bridge letter; evaluate alternate vendor if unresolved by contract renewal                                                                                                                  | Vendor Risk Manager           | 2026-03-31              | Open        |
| R-004   | 2026-01-20      | Business Continuity                  | Single AWS region deployment with no tested failover for claims processing platform                                   | Claims processing application (us-east-1) | Regional outage / Natural disaster      | No multi-region redundancy; DR runbook untested in 14 months                                  | 3                         | 5                     | 15                  | Critical            | Daily automated snapshots; documented (but untested) DR runbook                                             | 3                           | 4                         | 3                     | 12                  | High                | Mitigate       | Stand up warm standby in us-west-2; conduct tabletop DR exercise; update BIA recovery time objectives                                                                                                                                                 | Director of Infrastructure    | 2026-06-30              | Open        |
| R-005   | 2026-01-22      | Application Security                 | Customer-facing patient portal has not undergone penetration testing since acquisition of PortalWorks platform        | Patient self-service portal               | External attacker                       | Unknown vulnerability posture on acquired codebase                                            | 4                         | 4                     | 16                  | Critical            | WAF in front of portal; automated SAST scanning in CI pipeline                                              | 3                           | 3                         | 3                     | 9                   | Medium              | Mitigate       | Commission third-party penetration test; remediate critical/high findings before next release                                                                                                                                                         | AppSec Lead                   | 2026-03-15              | Open        |
| R-006   | 2026-02-02      | Insider Threat                       | Departed employees' access not consistently deprovisioned within policy SLA (24 hours)                                | All SaaS applications (Okta-federated)    | Malicious/negligent former employee     | Manual offboarding checklist; no automated SSO deprovisioning trigger                         | 3                         | 4                     | 12                  | High                | HR ticketing triggers manual IT offboarding task; monthly access audit                                      | 3                           | 2                         | 3                     | 6                   | Medium              | Mitigate       | Automate deprovisioning via Okta Lifecycle Management tied to HRIS termination event                                                                                                                                                                  | IAM Manager                   | 2026-04-15              | In Progress |
| R-007   | 2026-02-05      | Compliance / Regulatory              | Business Associate Agreements (BAAs) not on file for 2 of 11 active subcontractors handling PHI                       | Vendor management program                 | Regulatory (HHS OCR)                    | Contract lifecycle gap; no centralized BAA tracking system                                    | 2                         | 5                     | 10                  | High                | Legal review required before vendor onboarding (policy exists, enforcement inconsistent)                    | 2                           | 2                         | 4                     | 8                   | Medium              | Mitigate       | Build centralized BAA tracker; obtain missing BAAs within 30 days; add BAA checkpoint to procurement workflow                                                                                                                                         | Compliance Officer            | 2026-03-10              | Open        |
| R-008   | 2026-02-10      | Cloud / Infrastructure               | Production AWS S3 buckets identified with overly permissive bucket policies during quarterly config review            | Data lake / analytics staging             | External attacker / Data exposure       | Misconfiguration; no automated guardrail preventing public ACLs                               | 3                         | 5                     | 15                  | Critical            | AWS Config rules deployed post-discovery; buckets remediated same day as found                              | 1                           | 4                         | 1                     | 4                   | Low                 | Mitigate       | Enable AWS Config conformance pack + SCP to block public bucket policies account-wide; add to CI/CD pre-deploy checks                                                                                                                                 | Cloud Security Engineer       | 2026-02-28              | In Progress |
| R-009   | 2026-02-14      | Physical Security                    | Colocation data center badge access logs not reviewed on a recurring schedule                                         | Legacy colocation facility (non-AWS)      | Unauthorized physical access            | No formal quarterly physical access review process                                            | 2                         | 4                     | 8                   | Medium              | Badge system with logging; visitor escort policy                                                            | 2                           | 2                         | 3                     | 6                   | Medium              | Accept         | Add colo badge log review to quarterly physical security checklist; Medium residual risk (score 6) given facility is being decommissioned in migration                                                                                                | Facilities / Security Manager | 2026-05-01              | Open        |
| R-010   | 2026-02-18      | Change Management                    | Emergency changes to production billing system bypass standard change advisory board (CAB) review                     | Billing and revenue cycle system          | Operational error                       | Emergency change process lacks retrospective review requirement                               | 3                         | 4                     | 12                  | High                | Emergency changes logged in ticketing system after the fact                                                 | 3                           | 2                         | 3                     | 6                   | Medium              | Mitigate       | Require mandatory 48-hour post-implementation CAB review for all emergency changes; track in change management KPIs                                                                                                                                   | IT Change Manager             | 2026-04-01              | Open        |
| R-011   | 2026-02-20      | Data Protection                      | Marketing analytics team exports de-identified patient datasets to local laptops for ad-hoc analysis                  | Analytics / BI environment                | Data loss / Device theft                | No DLP controls on endpoint; de-identification method not independently validated             | 3                         | 3                     | 9                   | Medium              | Endpoint encryption (BitLocker/FileVault) enforced via MDM                                                  | 3                           | 2                         | 2                     | 4                   | Low                 | Mitigate       | Deploy DLP policy restricting bulk export; validate de-identification methodology against Safe Harbor standard; move analysis to governed workspace                                                                                                   | Data Governance Lead          | 2026-05-30              | Open        |
| R-012   | 2026-02-25      | Third-Party / Vendor                 | Payment processor integration relies on deprecated TLS 1.1 fallback for backward compatibility with one legacy client | Payment gateway integration               | External attacker (protocol downgrade)  | Legacy client dependency delaying TLS 1.1 deprecation                                         | 2                         | 4                     | 8                   | Medium              | TLS 1.2+ enforced for 98% of traffic; monitoring on legacy endpoint                                         | 2                           | 2                         | 3                     | 6                   | Medium              | Mitigate       | Migrate final legacy client to TLS 1.2 by contract deadline; disable TLS 1.1 fallback entirely                                                                                                                                                        | Director of Engineering       | 2026-06-01              | Open        |
| R-013   | 2026-03-01      | Human Resources / Security Awareness | Phishing simulation click rate (14%) exceeds industry benchmark and internal target (5%)                              | All employees (email)                     | External attacker (phishing/BEC)        | Insufficient security awareness training cadence; no role-based training for high-risk groups | 4                         | 3                     | 12                  | High                | Annual security awareness training; email banner tagging for external senders                               | 3                           | 2                         | 2                     | 4                   | Low                 | Mitigate       | Move to quarterly phishing simulations; targeted training for finance and HR (BEC-high-risk); track click rate as security KPI                                                                                                                        | Security Awareness Lead       | 2026-04-30              | In Progress |
| R-014   | 2026-03-05      | Application Security                 | API rate limiting not enforced on provider directory public API, enabling potential scraping/enumeration              | Provider directory API (public)           | External attacker (data scraping)       | No rate limiting or bot detection at API gateway                                              | 3                         | 2                     | 6                   | Medium              | API gateway logging enabled; basic authentication required for write operations                             | 2                           | 2                         | 1                     | 2                   | Low                 | Accept         | Accepted under ACC-014 by Elena Voss, COO, on 2026-03-12. Public directory data and Low residual score 2 do not justify immediate remediation cost. Monitor abuse; retain Q3 rate-limiting backlog. See Risk Acceptance for authority and conditions. | API Platform Lead             | 2026-07-31              | Open        |
| R-015   | 2026-03-10      | Business Continuity                  | Key-person dependency: single engineer holds undocumented knowledge of legacy claims adjudication rules engine        | Claims adjudication system                | Operational / Staffing                  | No documentation; no cross-training; high attrition risk role                                 | 3                         | 4                     | 12                  | High                | None formal; tribal knowledge only                                                                          | 3                           | 4                         | 3                     | 12                  | High                | Mitigate       | Document rules engine logic and decision tables; cross-train second engineer; add to succession plan. Inherent score 12 ties R-003, R-006, R-010, R-013 and R-017; R-015 stays at 12 residual because no formal controls are recorded.                | Engineering Manager           | 2026-05-15              | Open        |

# RISK REGISTER — METHODOLOGY & LEGEND

|                               |                                                                                                                                                                       |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Risk Scoring</b>           | Risk Score = Likelihood (1-5) x Impact (1-5). Range 1-25.                                                                                                             |
| <b>Critical</b>               | 15-25 — Immediate executive escalation and remediation required                                                                                                       |
| <b>High</b>                   | 10-14 — Remediation plan required within 30-60 days                                                                                                                   |
| <b>Medium</b>                 | 5-9 — Remediation plan required within 90 days, or documented risk acceptance                                                                                         |
| <b>Low</b>                    | 1-4 — Monitor; remediate opportunistically or formally accept                                                                                                         |
| <b>Likelihood Scale</b>       | 1=Rare, 2=Unlikely, 3=Possible, 4=Likely, 5=Almost Certain                                                                                                            |
| <b>Impact Scale</b>           | 1=Negligible, 2=Minor, 3=Moderate, 4=Major, 5=Severe (regulatory, financial, or patient-safety consequence)                                                           |
| <b>Risk Treatment Options</b> | Accept = retain risk within tolerance; Mitigate = reduce likelihood/impact via controls; Transfer = insurance/contract; Avoid = discontinue the activity              |
| <b>How to use this cells</b>  | Blue-bordered numeric cells (Likelihood/Impact/Effectiveness) are the editable inputs. Risk Score and Risk Level columns are formulas — do not hardcode.              |
| <b>Review Cadence</b>         | Full register reviewed quarterly by the GRC function; Critical/High risks reviewed monthly by risk owners; register updated continuously as new risks are identified. |

## TAVARES RISK ACCEPTANCE RECORD

|                            |                                                                                                                                                                                                                                     |  |            |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|------------|
| Scenario status            | Fictional decision and personnel, authored for this portfolio exercise. No real executive approval is represented.                                                                                                                  |  |            |
| Acceptance ID              | ACC-014                                                                                                                                                                                                                             |  |            |
| Related risk               | R-014                                                                                                                                                                                                                               |  |            |
| Decision                   | Accept with monitoring                                                                                                                                                                                                              |  |            |
| Acceptor                   | Elena Voss                                                                                                                                                                                                                          |  |            |
| Role                       | Chief Operating Officer                                                                                                                                                                                                             |  |            |
| Delegated authority        | Scenario risk charter delegates acceptance of Low residual operational risks involving public data to the COO. No authority to waive legal obligations or accept PHI disclosure risk.                                               |  |            |
| Decision date              |                                                                                                                                                                                                                                     |  | 2026-03-12 |
| Residual score at decision |                                                                                                                                                                                                                                     |  | 2          |
| Residual band              | Low                                                                                                                                                                                                                                 |  |            |
| Business rationale         | The directory is public by design. Immediate rate-limiting work would displace higher-priority PHI and access-control remediation; expected scraping exposure does not justify that cost. Q3 implementation remains in the backlog. |  |            |
| Risk owner                 | API Platform Lead                                                                                                                                                                                                                   |  |            |
| Conditions                 | Review gateway abuse logs monthly; escalate service degradation, unexpected nonpublic data exposure, or a material change in API usage to the COO and CISO. Acceptance must be reconsidered if any condition fails.                 |  |            |
| Scheduled review date      |                                                                                                                                                                                                                                     |  | 2026-07-31 |
| Acceptance expires         |                                                                                                                                                                                                                                     |  | 2026-12-31 |
| Review evidence            | This record documents the March decision only. A completed July review or renewal is not supplied.                                                                                                                                  |  |            |
| Closure evidence           | Rate-limiting configuration and validation of expected API behavior are required to close the remediation action. Acceptance alone does not close R-014.                                                                            |  |            |